

BÀI TẬP TÌNH HUỐNG – RSA TRONG HỆ THỐNG THỰC TẾ

Bài 1 – Lựa chọn triển khai RSA trong hệ thống thực tế

Một hệ thống thương mại điện tử cần:

- Bảo vệ thông tin thanh toán của khách hàng
- Truyền dữ liệu qua Internet
- Xác thực server với client

Nhóm phát triển đề xuất: Dùng RSA để mã hóa toàn bộ dữ liệu truyền đi

Bài làm

Hệ thống thương mại điện tử yêu cầu đảm bảo an toàn thông tin thanh toán, truyền dữ liệu qua Internet và xác thực giữa client và server. Nhóm phát triển đề xuất sử dụng RSA để mã hóa toàn bộ dữ liệu truyền đi. Tuy nhiên, đề xuất này chưa phù hợp trong thực tế do đặc điểm của thuật toán RSA.

- RSA có hiệu suất thấp do sử dụng phép toán lũy thừa modulo với số lớn.
- Không phù hợp để mã hóa dữ liệu lớn, chỉ phù hợp với dữ liệu nhỏ như khóa.
- Làm tăng độ trễ khi truyền dữ liệu qua mạng.
- Tốn tài nguyên server khi số lượng người dùng lớn.

Ví dụ: Nếu một website thương mại điện tử có hàng nghìn người dùng truy cập cùng lúc và mỗi người đều gửi dữ liệu thanh toán, việc mã hóa toàn bộ dữ liệu bằng RSA sẽ khiến hệ thống xử lý chậm và dễ bị quá tải.

Giải pháp tối ưu là sử dụng hệ mã hóa lai (Hybrid Cryptosystem), kết hợp giữa RSA và AES.

- AES được sử dụng để mã hóa dữ liệu vì tốc độ nhanh.

- RSA được sử dụng để mã hóa khóa AES nhằm đảm bảo an toàn.

=> Giúp hệ thống vừa đảm bảo bảo mật vừa tối ưu hiệu năng.

Ví dụ: Khi người dùng nhập thông tin thẻ ngân hàng, dữ liệu sẽ được mã hóa bằng AES. Sau đó, khóa AES được mã hóa bằng RSA trước khi gửi đến server. Server sẽ dùng Khóa bí mật để giải mã khóa AES và tiếp tục giải mã dữ liệu.

Câu 2: Sai lầm trong phân phối khóa công khai

Một người dùng tải khóa công khai RSA của server từ một website không xác thực.

Sau đó, gửi dữ liệu mã hóa bằng khóa này. Nhưng dữ liệu bị giải mã bởi hacker.

Bài làm

Trong tình huống người dùng tải public key từ một website không xác thực và sử dụng để mã hóa dữ liệu, việc dữ liệu bị hacker giải mã là do public key đã bị giả mạo.

- Người dùng không kiểm tra độ tin cậy của website.
- Hacker có thể thay thế public key thật bằng key giả.
- Dữ liệu bị mã hóa bằng key của hacker nên có thể bị giải mã.

Ví dụ: Một hacker tạo một website giả mạo giống với website chính thức và cung cấp public key của mình. Người dùng tải key này và sử dụng để mã hóa thông tin tài khoản. Hacker có thể dùng private key tương ứng để giải mã toàn bộ thông tin.

Đây là dạng tấn công Man-in-the-Middle (MITM), trong đó hacker đứng giữa client và server để đánh cắp dữ liệu.

- Hacker chặn và thay đổi public key trong quá trình truyền.
- Người dùng không phát hiện được sự thay đổi.

- Dữ liệu bị lộ mà không hay biết.

Để phòng chống, cần áp dụng các biện pháp bảo mật:

- Sử dụng HTTPS để đảm bảo kết nối an toàn.
- Sử dụng chứng chỉ số (Digital Certificate).
- Áp dụng hệ thống PKI để quản lý khóa.
- Không tải public key từ nguồn không tin cậy.

Ví dụ: Khi truy cập một website có HTTPS, trình duyệt sẽ kiểm tra chứng chỉ SSL(Secure Sockets Layer là một chứng chỉ số dùng để mã hóa dữ liệu giữa trình duyệt (client) và server (website)). Nếu chứng chỉ không hợp lệ, trình duyệt sẽ cảnh báo người dùng, giúp tránh bị tấn công.